

CODEALPHA INTERNSHIP PROGRAM
Internet of Things (IoT) Track

IoT Security Challenges

A Mini Case Study

Task 4 – Mini Project: IoT Case Study

Submitted by:

Victor CHITAMBO

Student ID:

CA/DF1/105890

Internship:

CodeAlpha – Internet of Things Internship

Task:

Task 4 – Mini Project: IoT Case Study

Topic Chosen:

IoT Security Challenges

June 2026

Contents

1 Introduction 2

1.1 Background and Motivation 2

1.2 Scope and Objectives 2

2 Why IoT Security Is Different 2

3 Key Security Challenges 2

3.1 Device-Level Vulnerabilities 2

3.2 Network and Communication Risks 2

3.3 Data Privacy Concerns 2

3.4 Authentication and Identity Management 3

3.5 Firmware and Patch Management 3

3.6 Physical and Supply-Chain Security 3

4 Notable Real-World Incidents 3

5 Mitigation Strategies and Best Practices 3

5.1 Security by Design 3

5.2 Network Segmentation and Zero Trust 3

5.3 Standards, Regulation, and Certification 4

5.4 Secure Update Mechanisms 4

6 Lessons from a Hands-On Smart Home Prototype 4

7 Future Outlook 5

8 Conclusion 5

1. Introduction

1.1. Background and Motivation

The Internet of Things has moved, within roughly a decade, from a research concept to a default feature of homes, factories, hospitals, and cities. Billions of sensors and embedded controllers now exchange data continuously, often outpacing the security practices that protected traditional computing systems. Unlike a laptop or a server, an IoT device frequently runs for years without a meaningful update, sits on a private network with little monitoring, and is built to a cost target that leaves scant room for cryptographic hardware – an attack surface that has grown faster than the tooling meant to defend it.

1.2. Scope and Objectives

This case study surveys the principal security challenges in consumer and industrial IoT, illustrates them with documented real-world incidents, and reviews the mitigation strategies the industry has converged on. It closes with observations drawn from a small ESP32-based smart home prototype built and tested directly by the author, before considering how the field is likely to evolve.

2. Why IoT Security Is Different

Several features distinguish IoT security from conventional IT security. Most devices are **resource-constrained**, with microcontrollers too limited to run a full cryptographic stack. The landscape is also extremely **heterogeneous**, combining countless hardware platforms and protocols, so no single patch or monitoring tool covers an entire deployment. Devices often have **long, unpredictable lifespans**, remaining in service well past their vendor’s support window, and many have **no screen or keyboard** through which a user could configure passwords or apply updates. Finally, IoT hardware is frequently **physically accessible** – a lock on a door, a sensor on a pipeline – expanding the practical opportunities for tampering or side-channel attacks.

3. Key Security Challenges

3.1. Device-Level Vulnerabilities

Many consumer IoT products ship with hard-coded or default credentials that are rarely changed, a weakness later exploited for large-scale botnet recruitment (Section 4). Limited processing power discourages strong encryption or secure boot, leaving firmware and credentials exposed once an attacker gains access. Debugging interfaces such as UART or JTAG, often left enabled in production hardware, give attackers with brief physical access a way to dump firmware or inject code, bypassing software-level protections.

3.2. Network and Communication Risks

Much IoT traffic still relies on protocols not designed with strong security guarantees, including plain HTTP and unauthenticated MQTT brokers. Unencrypted traffic lets an attacker on the same network segment intercept credentials or commands through simple man-in-the-middle techniques. Compromised devices are also a favored resource for distributed denial-of-service infrastructure, since one vulnerable firmware image can be used to infect tens of thousands of identical devices at once.

3.3. Data Privacy Concerns

Smart home and wearable devices continuously collect intimate data – occupancy patterns, voice recordings, location, and sometimes biometric readings – which typically passes through

manufacturer cloud platforms before reaching the user’s own app. This multiplies the organizations holding sensitive data and the potential points of failure, while inconsistent retention policies and opaque third-party sharing agreements compound the risk even without a malicious breach.

3.4. Authentication and Identity Management

At the scale of a smart factory or citywide sensor network, individually provisioning credentials for thousands of devices is difficult, so many deployments fall back on shared or default secrets. Establishing mutual authentication, so device and server can verify each other, requires certificate infrastructure many smaller manufacturers do not maintain, leaving a single compromised device able to impersonate a legitimate node or move laterally into adjacent systems.

3.5. Firmware and Patch Management

Many IoT devices lack a reliable, secure over-the-air update mechanism, so known vulnerabilities can remain unpatched for the device’s entire life. Fragmented supply chains and short support windows mean older product lines are often abandoned long before consumers replace the hardware, leaving a long tail of outdated, vulnerable firmware on home and corporate networks years after the flaws were disclosed.

3.6. Physical and Supply-Chain Security

Because IoT devices sit in uncontrolled physical environments, they face risks rarely seen by centralized servers, including tampering, component substitution, and counterfeit hardware introduced anywhere along the supply chain. A single untrusted component, whether a counterfeit chip or a maliciously modified firmware image installed before the device reaches the customer, can undermine every software-level protection built on top of it.

4. Notable Real-World Incidents

The challenges above are not theoretical; each has a documented real-world counterpart. Table 1 summarizes four incidents spanning vehicles, botnets, medical devices, and security cameras.

These cases share a pattern: the technical root cause is often mundane, a default password, an unauthenticated radio link, a leaked credential, yet the consequences scale because IoT devices are deployed identically and in enormous numbers. The Jeep and pacemaker cases show vulnerabilities crossing into the physical world, threatening safety rather than just data confidentiality; Mirai and Verkada show how one weak point can cascade far beyond the original device.

5. Mitigation Strategies and Best Practices

5.1. Security by Design

Security built in from the earliest design stage – eliminating hard-coded credentials, enabling secure boot and signed firmware, disabling unused ports before shipping – is consistently cheaper and more effective than retrofitting it after a product has already reached millions of customers.

5.2. Network Segmentation and Zero Trust

Placing IoT devices on a separate network segment limits the damage a single compromised device can cause. A zero-trust approach extends this by requiring every device to authenticate

Year	Incident	Attack Vector	Impact
2015	Jeep Cherokee remote hack	Vulnerability in the cellular-connected infotainment unit	Researchers remotely controlled steering and braking, prompting a recall of 1.4 million vehicles [1]
2016	Mirai botnet	Default Telnet credentials on IP cameras and home routers	Hundreds of thousands of devices recruited into a botnet behind a record-breaking DDoS attack on Dyn DNS [2]
2017	St. Jude Medical cardiac devices	Unauthenticated radio-frequency link to the implant	FDA-mandated firmware update for life-sustaining pacemakers and defibrillators [3]
2021	Verkada camera breach	Stolen “super admin” cloud credentials	Live feeds from roughly 150,000 connected cameras in hospitals, schools, and prisons accessed [4]

Table 1: Selected notable IoT security incidents.

and prove its identity before accessing other resources, rather than trusting anything already inside the network perimeter.

5.3. Standards, Regulation, and Certification

Several frameworks give manufacturers concrete requirements: the OWASP IoT Top 10 catalogs common weaknesses [5], NIST IR 8259 defines baseline manufacturer activities [6], and ETSI EN 303 645 bans universal default passwords [7]. Regulation is catching up too: the EU Cyber Resilience Act, in force since December 2024, requires security-by-design and vulnerability reporting for connected products, phasing in from September 2026 to full enforcement in December 2027 [8]. Industry alliances such as the Connectivity Standards Alliance promote interoperable standards like Matter [9].

5.4. Secure Update Mechanisms

A device that cannot receive a signed, authenticated update in the field is effectively unpatchable once a flaw is found. Reliable over-the-air pipelines, paired with a published support period and disclosure process, let manufacturers close gaps quickly rather than relying on a slow, costly recall.

6. Lessons from a Hands-On Smart Home Prototype

These principles become concrete against a small ESP32-based smart home prototype built for an academic embedded systems project, combining a DHT11 sensor with a relay-controlled lamp, exposed through HTTP endpoints and a companion mobile app. Built for a classroom demonstration, it prioritized functionality over hardening: its endpoints accepted commands without authentication, and traffic travelled unencrypted across the local network – exactly the kind of convenient shortcut that becomes a liability once shipped. Moving it toward production-grade security would require, at minimum, token-based authentication,

TLS-encrypted communication, and a signed firmware-update path – the same three measures most often absent from the incidents in Section 4.

7. Future Outlook

Machine-learning-based anomaly detection is increasingly used to flag unusual device behavior without requiring constant human review. Hardware security modules are becoming cheap enough for low-cost consumer devices, narrowing the gap with traditional computing hardware. Regulatory pressure, particularly from the EU Cyber Resilience Act, is expected to push manufacturers toward mandatory baselines rather than voluntary best practice, while broader adoption of standards such as Matter should reduce the fragmentation that makes IoT security difficult to manage at scale.

8. Conclusion

IoT security challenges arise less from any single dramatic flaw than from resource constraints, device heterogeneity, long lifespans, and weak update mechanisms, all deployed at a scale that turns small weaknesses into large incidents. The cases examined here, spanning vehicles, botnets, implants, and cameras, show the breadth of what is at stake, while the smart home prototype shows how easily insecure defaults creep into even a small, well-intentioned project. Closing this gap requires manufacturers, standards bodies, and regulators to keep building security in from the start rather than patching it on afterward.

References

- [1] C. Miller and C. Valasek, “Remote Exploitation of an Unaltered Passenger Vehicle,” *Black Hat USA*, 2015.
- [2] M. Antonakakis et al., “Understanding the Mirai Botnet,” *Proceedings of the 26th USENIX Security Symposium*, 2017.
- [3] U.S. Food and Drug Administration, “Firmware Update to Address Cybersecurity Vulnerabilities Identified in Abbott’s (formerly St. Jude Medical) Implantable Cardiac Pacemakers,” FDA Safety Communication, 2017.
- [4] Axios, “Hackers Breach Verkada Security Cameras,” <https://www.axios.com/2021/03/09/hackers-breach-verkada-security-cameras>, March 2021.
- [5] OWASP Foundation, “OWASP Internet of Things Top 10,” <https://owasp.org>, 2018.
- [6] National Institute of Standards and Technology, “NISTIR 8259: Foundational Cybersecurity Activities for IoT Device Manufacturers,” 2020.
- [7] ETSI, “ETSI EN 303 645: Cyber Security for Consumer Internet of Things: Baseline Requirements,” 2020.
- [8] European Union, “Regulation (EU) 2024/2847 on Cybersecurity Requirements for Products with Digital Elements (Cyber Resilience Act),” *Official Journal of the European Union*, 2024.
- [9] Connectivity Standards Alliance, “Matter – The Foundation for Connected Things,” <https://csa-iot.org/all-solutions/matter/>, accessed June 2026.